

## Experiment 9 — Compliance Assessments: Test of Design and Test of Operational Effectiveness

### Title

Compliance Assessment using Test of Design (ToD) and Test of Operational Effectiveness (ToOE)

### Aim

To perform a compliance assessment in Eramba by evaluating compliance requirements through Test of Design (ToD) and Test of Operational Effectiveness (ToOE) and linking them with policies, controls, and risks.

### Procedure

1. Log in to the Eramba GRC platform.
2. Navigate to **Compliance Management** → **Compliance Packages**.
3. Create a compliance package named *Exp 9 Information Security Compliance Assessment*.
4. Add compliance requirements to the package using the *Compliance Package Items* section.
5. Import/configure 20 compliance items covering areas such as access control, data protection, incident management, vulnerability management, backup, and business continuity.
6. Navigate to **Compliance Management** → **Compliance Analysis**.
7. Select the created compliance package and view the compliance requirements.
8. Open a compliance item such as **DP-02 – Data Retention**.
9. Configure the Compliance Strategy as *Compliant* and assign the responsible owner.
10. Link relevant internal controls, policies, and business risks to the compliance item.
11. Document the Test of Design (ToD), verifying that the required policy/process is properly designed and documented.
12. Document the Test of Operational Effectiveness (ToOE), verifying that the control is actually operating and supporting evidence exists.
13. Save the compliance assessment and review the resulting compliance status.

### Output

A compliance package containing 20 requirements was created and assessed. The selected compliance requirement was configured with a compliance strategy, owner, supporting controls, policies, and related risks. ToD and ToOE procedures were documented for evaluating both the design and actual operation of the compliance control.

